3.8. Безопасное программирование защита от ошибок и атак

3. Сети, базы данных, безопасность кода

В этом уроке

- Интеграция безопасности в разработку (SAST, DAST, автоматизация тестирования).
- Проверка формата данных (email, пароль), использование белых списков.
- Создание безопасной формы входа с защитой от SQL-инъекций и XSS.
- Примеры использования регулярных выражений, параметризованных запросов, SonarQube.

Практическое задание
Валидация ввода (Python)

Написать функцию для проверки корректности email-адреса.

Условие:

- Email должен содержать символ @ и точку в доменной части.
- Допустимые символы: буквы (a-z, A-Z), цифры (0-9), точки (.), дефисы (-), подчеркивания (_).

Пример корректного email: user.name@example.com.

Защита от SQL-инъекций (Python + SQLite)

Написать безопасный SQL-запрос для аутентификации пользователя.

Условие:

- Использовать параметризованные запросы.
- Проверить логин и пароль в базе данных.

Ограничение попыток входа (Python)

Реализовать механизм блокировки после 3 неудачных попыток входа.

Условие:

- Использовать словарь для хранения количества попыток.
- Блокировать пользователя на 5 минут при превышении лимита.

Скринкаст

Итоги урока

- Научились проверять и фильтровать пользовательский ввод (валидация email через regex).
- Освоили защиту от SQL-инъекций (параметризованные запросы) и XSS (экранирование данных).
- Поняли принципы DevSecOps: внедрение безопасности на этапах разработки и тестирования.
- Применили навыки для создания безопасных форм и анализа кода с инструментами вроде OWASP ZAP.